

1/24

□

File No.: EXP202213323

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On December 4, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against SHANGHAI MOONTON TECHNOLOGY CO. LTD (hereinafter, the respondent), through the Agreement that is transcribed:

<<

File No.: EXP202213323

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On November 21, 2022, this Agency was notified of a violation of the security of personal data reported by SHANGHAI MOONTON TECHNOLOGY CO. LTD with NIF in China

91310101091821567U (hereinafter, MOONTON) as the data controller. As a consequence of the known facts, on December 12, 2022, the Director of the Spanish Agency for Data Protection ordered the appropriate preliminary investigations to determine a possible violation of data protection regulations.

The received document informed of the following:

o

Date of breach initiation: 02/11/2022.

o

Date of breach detection: 04/11/2022.

o

The data is not encrypted.

o

Summary of the incident: "(...)"

o

Category of affected data: contact data and profile data.

o

Category of affected individuals: users.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/24

o

Number of affected individuals: 839 in Spain. More than 20,000 affected individuals in all Member States of the Union, all Control Authorities of the Union have been notified.

o

No notification has been made to law enforcement authorities.

o

The affected individuals will not be notified.

SECOND: On December 29, 2022, MOONTON made an additional notification of the violation of the security of personal data, in which it stated:

"As indicated in the initial notification, Shanghai Moonton Technology Co. Ltd ("Moonton") suffered, on November 2, 2022, a violation of the security of its data when certain information related to the users of its Forum was published on a third-party website. (...)"

THIRD: The General Subdirectorate of Data Inspection proceeded to carry out preliminary

investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following aspects:

1) MOONTON is a developer and publisher of video games of Chinese nationality based in Shanghai. According to data available on MOONTON's website and <https://hmong.es/wiki/Moonton>, MOONTON was founded in 2014 and is known for the game "Mobile Legends: Bang Bang," an online multiplayer game released in 2016. On March 22, 2021, the developer of Tik Tok, BABE, Resso, and Lark, ByteDance, through its video game subsidiary Nuverse, acquired MOONTON.

2) On March 21, 2023, an initial response to a request from the AEPD was registered, registration number ***REGISTRO.1, and on March 27, 2023, supplementary documentation was submitted, registration numbers ***REGISTRO.2 and ***REGISTRO.3. On May 17 and 22, 2023, documentation from MOONTON that had been previously submitted was again registered with the AEPD.

On June 12, 2023, this Agency requested additional information. On July 7, 2023, the response from MOONTON to this request was registered with the AEPD, registration number ***REGISTRO.4.

Once the documentation provided by MOONTON was reviewed, the following relevant information was extracted:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/24

Regarding the chronology of events. Actions taken to minimize adverse effects and measures adopted for final resolution

-

November 2, 2022: Date of publication of the personal data of the members of the Forum on a third-party website (**URL.1) (the "Website").

-

November 3, 2022: Date on which a member of the Company's security team, while performing their duties of monitoring and safeguarding the security of the company's information and its users, identified the publication of the data on the Website.

(...)

-

November 4, 2022 to November 16, 2022: The Company continued investigating the data security breach to ascertain its scope and determine additional measures that the Company could implement to limit any damage or harm that affected users might suffer. In this regard, on November 4, 2022, the Company confirmed that some of the users affected by the breach were located in the European Economic Area.

(...)

Regarding the causes that made the breach of personal data security possible

(...)

Regarding the affected data

(...)

These categories of data included: (i) username in the Forum and user identification number (User ID); (ii) the number of visits by users to the user spaces of the Forum; (iii) the gender declared by users (e.g., male, female, or undisclosed); and (iv) activity in the Forum, which includes "reputation," "wealth," and "contribution" to the Forum, all linked to users' posts, participation in the forum, and interactions between users.

It is noteworthy that the only non-public information for all users of the Forum (...) was: (i) the email address provided by users to register in the Forum; (ii) the registration date in the Forum; (iii) the date and time of the last activity of each user in the Forum; and (iv) the user's IP address (both the registration IP address and the IP address of the last visit).

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/24

(...)

MOONTON states that the total number of users of the Forum worldwide is approximately 800,670 users. It adds that it wishes to clarify that, although the notifications of the breach sent to the AEPD indicated that 839 users of the Forum located in Spain had been affected by the incident, after further investigations, it has confirmed that the total number of users located in Spain affected is 442. The Company has determined this number after analyzing the IP addresses associated with the accounts affected by the breach. The Company does not collect data from its users regarding their nationality or country of birth.

Furthermore, it states that it identified the location of all affected parties by the breach and proceeded to notify all relevant supervisory authorities.

In summary, the data that has been affected includes the data related to the username of the Forum and User ID (this data is public in the Forum itself), as well as the email address and the IP address.

Security measures implemented

-

Security measures implemented prior to the breach in the data processing where it occurred.

(...)

-

Reason why the security measures implemented did not prevent the incident.

(...)

-

Technical and organizational measures adopted to avoid, as much as possible, incidents like the one that occurred.

(...)

Regarding the notification after 72 hours

MOONTON states that the Company became aware of the data security breach on November 3, 2022, initiating an internal investigation at that moment with the aim of identifying the scope and impact of this on the rights and freedoms of the affected parties.

Although on November 4, 2022, the Company was already aware that several users located in the European Economic Area might have been affected, it continued its investigations until November 16 to confirm the nature of the incident, its scope, and the number of affected parties in each Member State. Notwithstanding the above, as it obtained and verified the information gathered in the context of the investigation, as well as identifying the number of affected users in each jurisdiction, the Company C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es

5/24

proceeded to notify the violation of data security to the competent control authorities and to block access to the Forum in those jurisdictions. In this regard, the Company began notifying the incident to the competent control authorities on November 11, 2022.

It should be noted that the Company does not have a legal establishment in Spain; therefore, before it could make the corresponding notification to the AEPD, it had to contact and hire a legal advisor located in this country (this has also occurred in the other 27 Member States of the European Union) to prepare the necessary notification and gather the information required by each control authority. This included the preparation of the necessary documentation so that the legal advisor in Spain could submit the relevant notification to the AEPD, which caused a delay in sending the notification to the AEPD.

MOONTON states that the Company does not have, as it is not obligated to do so, a digital certificate

through which it could access the AEPD's Electronic Headquarters and make the corresponding notification; therefore, it had to be done via postal mail (although an attempt was made to do so via email).

Information on the recurrence of these events and the number of similar events that have occurred over time

MOONTON states that it is not aware of any incident or violation of data security that occurred prior to the one notified to the AEPD and has not received, to date, any claims or requests from interested parties in Spain regarding this data security breach.

It has also not identified any other unauthorized publication or disclosure of personal data of the Forum users.

3) On October 16, 2023, in response to a request from this Agency, MOONTON stated that it has designated ***COMPANY.1, based in Ireland, as its representative in the European Union on January 25, 2023, in compliance with Article 27 of the GDPR.

LEGAL GROUNDS

I

Competence and procedure

In accordance with the powers granted to each control authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/24

Likewise, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary issues

In this case, in accordance with the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, since MOONTON was collecting and storing, among others, the following personal data of individuals: email address and IP address, among other processing activities.

MOONTON was carrying out this activity in its capacity as data controller, as it was the one determining the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

III

Data minimization

Article 5.1.c) of the GDPR "Principles relating to processing" establishes:

"1. Personal data shall be:

(...)

c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimization'); (...)"

In this case, MOONTON had granted access to the Moderators to the following personal data of users located in Spain of the Forum: (i) username in the Forum and user identification number (User ID); (ii) the number of visits of users to the user spaces of the Forum; (iii) the gender declared by users (e.g., male, female, or undisclosed); and (iv) activity in the Forum, which includes "reputation," "wealth," and "contribution" to the Forum, all linked to users' posts, participation in the forum, and interactions between users.

While MOONTON has highlighted that the only non-public information for all Forum users to which the

moderators had access was: (i) the email address provided by users to register in the Forum; (ii) the registration date in the Forum; (iii) the date and time of the last activity of each user in the Forum; and (iv) the user's IP address (both the registration IP address and the last visit IP address).

The purpose for which access to such data was granted to the Moderators was to moderate the Forums of MOONTON's games, for which MOONTON had granted them administrator permissions that allowed them to access this information.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/24

regarding the users of the Forum in order to carry out, primarily, the tasks of moderating the conversations, which involved, for example: (i) the review and removal of posts; (ii) the blocking or removal of access to the Forum for certain users; (iii) responding to inquiries made by users; and (iv) approving registration requests for new users in the Forum.

In this regard, this Agency considers that in order to moderate such Forums and remove users' posts or prevent access to the Forum, and review responses to inquiries or approve new users, it was not necessary for the Moderators to have access to all that information, especially the user's email address and IP address. It is the opinion that this data was not relevant for carrying out such tasks and was not strictly limited to the purposes for which it was intended.

Therefore, in accordance with the evidence available at this time regarding the initiation of sanctioning proceedings, and without prejudice to the outcome of the investigation, it is considered that the known facts could constitute an infringement, attributable to MOONTON, for violation of the previously transcribed article.

IV

Classification and qualification of the infringement of Article 5.1.c) of the GDPR

If confirmed, the aforementioned infringement of Article 5.1.c) of the GDPR could constitute one of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"5. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

For the purposes of the statute of limitations for infringements, the alleged infringement is subject to a three-year limitation period, in accordance with Article 72 of the LOPDGDD, which qualifies the following conduct as very serious:

"1. According to what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a three-year limitation period:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/24

V

Proposal for sanction for the infringement of Article 5.1.c) of the GDPR

This infringement may be sanctioned with a fine of up to €20,000,000 or, in the case of an undertaking, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.5 of the GDPR.

For the purposes of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this time regarding the initiation of sanctioning proceedings, and without prejudice to the outcome of the investigation, it is considered appropriate to scale the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm they have suffered (paragraph a): for having granted access to the Forum Moderators to more data than strictly necessary to perform their duties, which affected the personal data of at least 442 parties, at least until November 11, 2022.

Furthermore, it is considered appropriate to scale the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD:

As aggravating factors:

- The link of the infringer's activity with the processing of personal data (paragraph b): MOONTON's activity requires habitual processing of personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating what is established in Article 5.1.c) of the GDPR, allows for an initial administrative fine of €30,000 to be set.

VI

Integrity and confidentiality

Article 5.1.f) of the GDPR “Principles relating to processing” states:

“1. Personal data shall be:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/24

(...)

f) treaties in such a way as to ensure an adequate level of security for personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures (“integrity and confidentiality”). (...)”

In the present case, the names and user IDs, email addresses, and IP addresses of 442 users located in Spain have been published on a third-party website.

Therefore, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to the outcome of the instruction, it is considered that the known facts could constitute an infringement attributable to MOONTON for violation of the previously transcribed article.

VII

Classification and qualification of the infringement of Article 5.1.f) of the GDPR

If confirmed, the aforementioned infringement of Article 5.1.f) of the GDPR could constitute one of the infringements classified in Article 83.5 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“5. Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total global annual turnover of the preceding financial year, opting for the higher amount:

- a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)”

For the purposes of the statute of limitations for infringements, the alleged infringement is subject to a three-year limitation period, in accordance with Article 72 of the LOPDGDD, which qualifies the following conduct as very serious:

“1. According to what is established in Article 83.5 of Regulation (EU) 2016/679, the following

infringements are considered very serious and shall be subject to a three-year limitation period:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VIII

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/24

Proposal for sanction for the infringement of Article 5.1.f) of the GDPR

This infringement may be sanctioned with a fine of up to €20,000,000 or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total global annual turnover of the preceding financial year, opting for the higher amount, in accordance with Article 83.5 of the GDPR.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to the outcome of the instruction, it is considered appropriate to scale the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered (paragraph a): due to the publication on a third-party website of the names and user IDs, email addresses, and IP addresses of 442 users located in Spain. Furthermore, it is considered appropriate to scale the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- The link of the infringer's activity with the processing of personal data (paragraph b): MOONTON's activity requires habitual processing of personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, allows for an initial administrative fine of €30,000.

IX

Security measures

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/24

b) the ability to ensure the confidentiality, integrity, availability, and permanent resilience of the processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process of regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of the processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks

presented by the data processing, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to a code of conduct approved pursuant to Article 40 or to a certification mechanism approved pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The data controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law. In this case, MOONTON had a role as a moderator to specifically moderate the discussions that were active in the Forums of its games.

In this regard, for example, it was responsible for reviewing and/or deleting posts, blocking access to the Forum for those users who violated its rules, responding to user inquiries, approving registration requests, among others.

To this end, MOONTON had granted the Moderator administrative rights that allowed access to the following user data from the Forum: (i) username in the Forum and user identification number (User ID); (ii) the number of visits by users to the user spaces of the Forum; (iii) the gender declared by users (e.g., male, female, or undisclosed); and (iv) activity in the Forum, which includes "reputation," "wealth," and "contribution" to the Forum, all linked to user posts, participation in the forum, and interactions between users.

The Moderator was not an employee of MOONTON, nor was he an employee of a service provider/subcontractor of MOONTON. The Moderator was merely a user of the Forum who voluntarily offered to help moderate the Forum.

MOONTON required the Moderator to adhere to the Code of Conduct for External Service Providers in his capacity as a moderator. This Code was made available to all moderators, who, in their capacity as users of the Forum, would also have had to adhere to the Basic Regulation of the Forum and the Terms and Conditions of the Forum.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/24

In the document "Code of Conduct for External Service Providers of the Company" of MOONTON (in its Spanish translation), it is indicated, among other things, that:

"Service Providers must make their utmost efforts to protect... the confidential information (including, but not limited to, personal data) of Moonton and its clients, refraining from disclosing it to third parties without the prior written consent of Moonton, as well as from using or exploiting it for purposes unrelated to the provision of the service" (point 3.2 of the document).

And that: "Moonton is committed to the protection and security of its information... The following actions will constitute a breach of Moonton's information security obligations, which will be subject to disciplinary measures of varying degrees depending on the severity. In the event of a violation of the law, Moonton will also cooperate with the competent judicial authorities in the corresponding legal actions.

(...) e) Acquiring, disclosing, or selling personal data or user statistics, client partner data, or other stakeholder groups by improper means or taking advantage of one's position to violate the privacy of third parties" (point 3.3 of the document).

To become a moderator, the Moderator filled out an application form made available to users by MOONTON, which was subsequently reviewed by the Company. Once the application was approved, the Moderator entered a two-week trial period, after which they became a moderator of the Forum. This procedure was common for all users wishing to serve as moderators.

That is to say, MOONTON allowed access to a user of its games (who was granted administrator permissions) to the personal data of other users located in Spain, who was neither an employee of MOONTON nor of a contracted or subcontracted company by MOONTON, and was provided with the

email addresses and IP addresses of such users, with no more security measures than a simple adherence to a Code of Conduct and the Basic Regulation of the Forum and its Terms and Conditions, along with a two-week trial period.

In this regard, this Agency considers that the measures implemented prior to the occurrence of the personal data security breach were clearly insufficient and cannot be considered adequate in terms of Article 32 of the GDPR.

However, once MOONTON became aware that the Moderator had published the data of other Forum users on a third-party website, it proceeded to block their access to the Forum and additionally informed them that their access to the Forum had been canceled as a result of the unauthorized publication.

Furthermore, MOONTON has decided to permanently disable the Forum throughout the European Economic Area. For this decision, among other reasons, the incident that occurred, the risks that its continuation may pose to the rights and freedoms of the data subjects located in the European Union in relation to the business and activities of the Company, as well as the fact that the business benefits of managing this Forum do not compensate for the resources necessary for its maintenance, have been taken into account. It stated that access to the Forum will remain blocked for users from the European Union until its total and permanent closure occurs in April 2023.

Therefore, in accordance with the evidence currently available in this initiation agreement for sanctioning proceedings, and without prejudice to what results from the instruction, it is considered that the known facts could constitute an infringement attributable to MOONTON for violation of the previously transcribed article.

X

Classification and qualification of the infringement of Article 32 of the GDPR

If confirmed, the aforementioned infringement of Article 32 of the GDPR could constitute one of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

For the purposes of the statute of limitations for infringements, the alleged infringement is subject to a two-year limitation period, in accordance with Article 73 of the LOPDGDD, which qualifies the following conduct as serious:

"According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and will be subject to a two-year statute of limitations: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.

XI

Proposal for sanction for the infringement of Article 32 of the GDPR

This infringement may be sanctioned with a fine of up to €10,000,000 or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total global annual turnover of the previous financial year.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/24

total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.4 of the GDPR.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to scale the sanction to be imposed according to the following criteria established by Article 83.2 of the GDPR:

As aggravating factors:

- The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected data subjects and the level of damage and harm they have suffered (paragraph a): for not having implemented appropriate security measures against the risk of a personal data breach such as the one that has occurred in this case, which allowed the confidentiality of the data of the user's name and user ID, email address, and IP address of 442 users located in Spain to be at risk.

As mitigating factors:

- Any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or losses avoided, directly or indirectly, through the infringement (paragraph k): once MOONTON became aware that the Moderator had published the data of other Forum users on a third-party website, it proceeded to block their access to the Forum and additionally informed them that their access to the Forum had been canceled as a consequence of the unauthorized publication. Furthermore, MOONTON has decided to permanently disable the Forum throughout the European Economic Area until its total and permanent closure in April 2023.

It is also considered appropriate to scale the sanction to be imposed according to the following criteria established by paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- The link of the infringer's activity with the processing of personal data (paragraph b): MOONTON's activity requires habitual processing of personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, allows for an initial administrative fine of 15,000 euros.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/24

XII

Notification to the supervisory authority

Article 33 "Notification of a personal data breach to the supervisory authority" of the GDPR establishes:

"1. In the case of a personal data breach, the data controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, no later than 72 hours after becoming aware of it, unless the breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification to the supervisory authority does not take place within 72 hours, it shall be accompanied by the reasons for the delay.

2. The processor shall notify the controller without undue delay of any personal data breaches of which it becomes aware.

3. The notification referred to in paragraph 1 shall, at a minimum:

- a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of affected data subjects, and the categories and approximate number of personal data records affected;

- b) communicate the name and contact details of the data protection officer or another contact point where more information can be obtained;

- c) describe the possible consequences of the personal data breach;

- d) describe the measures taken or proposed by the controller to remedy the personal data breach, including, where appropriate, the measures taken to mitigate any possible negative effects.

4. If it is not possible to provide the information simultaneously, and to the extent that it is not possible,

the information shall be provided in phases without undue delay.

5. The controller shall document any personal data breaches, including the facts relating to the breach, its effects, and the remedial measures taken. This documentation shall enable the supervisory authority to verify compliance with the provisions of this article.”

In this case, it is noted that MOONTON suffered a personal data breach on November 2, 2022, of which it became aware on November 4, 2022, and did not inform this Agency until November 21, 2022, the date on which the aforementioned personal data breach was notified, without having substantiated the reasons justifying such delay.

Therefore, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the known facts could constitute a

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/24

offense, attributable to MOONTON, for violation of the previously transcribed article.

XIII

Classification and qualification of the infringement of Article 33 of the GDPR

If confirmed, the aforementioned infringement of Article 33 of the GDPR could constitute one of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

For the purposes of the statute of limitations for infringements, the alleged infringement is subject to a two-year limitation period, in accordance with Article 73 of the LOPDGDD, which qualifies the following conduct as serious:

"According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a two-year limitation period, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

r) The failure to notify the data protection authority of a personal data security breach in accordance with the provisions of Article 33 of Regulation (EU) 2016/679. (...)"

XIV

Proposal for sanction for the infringement of Article 33 of the GDPR

This infringement may be sanctioned with a fine of up to €10,000,000 or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.4 of the GDPR.

For the purposes of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to gradate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/24

As aggravating factors:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or

purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm suffered (paragraph a): for failing to notify the data protection authority that a personal data security breach had occurred within 72 hours, of which it became aware on November 4, 2022, and was not reported until November 21, 2022, without any legitimate reasons justifying such delay being apparent.

It is also considered appropriate to gradate the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- The link of the infringer's activity with the processing of personal data (paragraph b): MOONTON's activity requires habitual processing of personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, with respect to the infringement committed by violating what is established in Article 5.1.f) of the GDPR, allows for an initial administrative fine of €5,000 to be set.

XV

Representatives of controllers not established in the Union

Article 27 "Representatives of controllers or processors not established in the Union" of the GDPR states:

"1. When Article 3, paragraph 2 applies, the controller or processor shall designate a representative in the Union in writing.

2. The obligation established in paragraph 1 of this article shall not apply:

- a) to processing that is occasional, that does not include large-scale processing of special categories of data referred to in Article 9, paragraph 1, or of personal data relating to criminal convictions and offenses referred to in Article 10, and that is unlikely to result in a risk to the rights and freedoms of natural persons, taking into account the nature, context, scope, and purposes of the processing, or
- b) to public authorities or bodies.

3. The representative shall be established in one of the Member States where the data subjects whose personal data are processed in the context of an offer of goods or services are located, or whose behavior is being monitored.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/24

4. The data controller or the processor shall appoint a representative to address, together with the controller or the processor, or in their place, inquiries, in particular, from supervisory authorities and data subjects, regarding all matters related to processing, in order to ensure compliance with the provisions of this Regulation.

5. The designation of a representative by the controller or the processor shall be understood without prejudice to actions that may be taken against the controller or processor themselves.

For its part, Article 3 "Territorial Scope" of the GDPR states:

"(...)

2. This Regulation applies to the processing of personal data of data subjects who are in the Union by a controller or processor not established in the Union, when the processing activities are related to:

- a) the offering of goods or services to such data subjects in the Union, regardless of whether payment is required from them, or
- b) the monitoring of their behavior, to the extent that it takes place in the Union. (...)"

In the present case, MOONTON is established in China, although it offers its services to data subjects in the European Union, so the provisions of Article 27 of the GDPR apply to it.

However, MOONTON had not designated a representative in the European Union, as required by the provisions of Article 27 of the GDPR, at least until the end of January 2023.

Therefore, in accordance with the evidence available at this moment of the initiation of sanctioning

procedure, and without prejudice to what results from the instruction, it is considered that the known facts could constitute an infringement attributable to MOONTON for violation of the previously transcribed article.

XVI

Classification and qualification of the infringement of Article 27 of the GDPR

If confirmed, the aforementioned infringement of Article 27 of the GDPR could constitute one of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total global annual turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

For the purposes of the statute of limitations for infringements, the infringement attributed prescribes after two years, according to Article 73 of the LOPDGDD, which qualifies the following conduct as serious:

"According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall prescribe after two years, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

h) The failure to designate a representative of the controller or processor not established in the territory of the European Union, as provided for in Article 27 of Regulation (EU) 2016/679. (...)"

XVII

Proposal for sanction for the infringement of Article 27 of the GDPR

This infringement may be sanctioned with a fine of up to €10,000,000 or, in the case of an undertaking, an amount equivalent to up to 2% of the total global annual turnover of the preceding financial year, opting for the higher amount, in accordance with Article 83.4 of the GDPR.

For the purposes of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to scale the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected data subjects and the level of damage and harm they have suffered (paragraph a): for not having designated a representative in the European Union until at least January 25, 2023.

It is also considered appropriate to scale the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/24

- The connection of the infringer's activity with the processing of personal data (section b): the activity of MOONTON requires a regular processing of personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 27 of the GDPR, initially allows for the imposition of an administrative fine of 10,000 euros.

XVIII

Imposition of Measures

If the infringement is confirmed, in accordance with the provisions of the aforementioned Article 58.2 d)

of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time...", the resolution adopted may require MOONTON to notify this Agency within SIX MONTHS that it has adopted the appropriate security measures to align its actions with the regulations mentioned in this act, without prejudice to others that may arise from the instruction of the procedure.

The imposition of these measures is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

It is warned that failure to comply with the possible order to adopt measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning procedures.

Furthermore, it is reminded that neither the acknowledgment of the infringement committed nor, where applicable, the voluntary payment of the proposed amounts exempts the obligation to demonstrate compliance with the proposed corrective measures.

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection, IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against SHANGHAI MOONTON TECHNOLOGY CO. LTD with NIF in China 91310101091821567U, for the alleged infringement of Articles 5.1.c) and 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR, and for the alleged infringement of Articles 32, 33, and 27 of the GDPR, classified in Article 83.4 of the GDPR.

SECOND: TO APPOINT R.R.R. as the instructor and S.S.S. as the secretary, indicating that they may be recused, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the file, for evidentiary purposes, the notification of the violation of the security of personal data, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the actions prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be, without prejudice to what results from the instruction, an administrative fine of 90,000.00 euros in total, distributed as follows:

- For the alleged infringement of Article 5.1.c) of the GDPR, classified in Article 83.5 of that regulation, an administrative fine of 30,000.00 euros.
- For the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of that regulation, an administrative fine of 30,000.00 euros.
- For the alleged infringement of Article 32 of the GDPR, classified in Article 83.4 of that regulation, an administrative fine of 15,000.00 euros.
- For the alleged infringement of Article 33 of the GDPR, classified in Article 83.4 of that regulation, an administrative fine of 5,000.00 euros.
- For the alleged infringement of Article 27 of the GDPR, classified in Article 83.4 of that regulation, an administrative fine of 10,000.00 euros.

FIFTH: TO NOTIFY this agreement to SHANGHAI MOONTON TECHNOLOGY CO. LTD with NIF in China 91310101091821567U, granting a hearing period of ten working days for it to submit allegations and present any evidence it deems appropriate. In its written allegations, it must provide its NIF and the procedure number that appears in the heading of this document.

If no allegations are made regarding this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

In accordance with the provisions of Article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the submission of allegations to this initiation agreement; this will entail a 20% reduction of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at 72,000.00 euros, resolving the procedure with the imposition of this sanction.

Similarly, it may, at any time prior to the resolution of this procedure, make a voluntary payment of the proposed sanction, which will entail a 20% reduction of its amount. With the application of this reduction,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
22/24

The penalty shall be established at 72,000.00 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the penalty is cumulative with the one that corresponds to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to submit allegations regarding the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions are applicable, the amount of the penalty shall be established at 54,000.00 euros.

In any case, the effectiveness of either of the two mentioned reductions shall be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the penalty.

In the event that you choose to proceed with the voluntary payment of either of the amounts indicated above (72,000.00 euros or 54,000.00 euros), you must make it effective by depositing it into account no. IBAN: ES00-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which you are adhering.

You must also send the proof of deposit to the General Subdirectorate of Inspection to continue with the procedure in accordance with the amount deposited.

The procedure shall have a maximum duration of twelve months from the date of the initiation agreement. If this period elapses without a resolution being issued and notified, it will result in its expiration and, consequently, the filing of actions; in accordance with the provisions of Article 64 of the LOPDGDD.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

935-270423

Mar España Martí
Director of the Spanish Agency for Data Protection

>>

SECOND: On January 2, 2024, the respondent has proceeded to pay the penalty in the amount of 72,000 euros, making use of one of the two reductions provided for in the previously transcribed Initiation Agreement. Therefore, the acknowledgment of responsibility has not been established.

THIRD: The payment made entails the renunciation of any action or administrative appeal against the penalty, in relation to the facts referred to in the Initiation Agreement.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

23/24

LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the

guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), under the heading "Termination in sanctioning procedures" provides the following:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate penalty.

2. When the penalty is solely of a pecuniary nature or when a pecuniary penalty can be imposed along with a non-pecuniary penalty but the latter has been justified as inappropriate, voluntary payment by the alleged responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for damages caused by the commission of the infringement.

3. In both cases, when the penalty is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed penalty, which shall be cumulative. The aforementioned reductions must be determined in the notification of initiation of the procedure, and their effectiveness shall be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the penalty. The percentage of reduction provided in this section may be increased by regulation."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/24

In accordance with the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202213323, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO NOTIFY this resolution to SHANGHAI MOONTON TECHNOLOGY CO. LTD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

937-17112023

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es